

Formula Road — Security Report

Оценка защищённости системы маршрутизации DILER BMD

ДАТА

28 мая 2026

ВЕРСИЯ

2.0 — актуальное состояние

ОБЛАСТЬ

PWA + API + Инфраструктура

СТАТУС СИСТЕМЫ

🔑 На обслуживании

КОНФИДЕНЦИАЛЬНОСТЬ

INTERNAL

15

МЕР ЗАЩИТЫ
АКТИВНО

0

ОСТАТОЧНЫХ
РИСКОВ

0

КРИТИЧЕСКИХ
ОТКРЫТЫХ

8h

TTL
СЕССИОННОГО
ТОКЕНА

1. Архитектура системы

УРОВЕНЬ	ТЕХНОЛОГИЯ	ОПИСАНИЕ
КЛИЕНТ	HTML5 PWA Leaflet localStorage	Single-page приложение formula-road.html на GitHub Pages. Аутентификация через сессионный токен, полученный от сервера. Все запросы к API включают X-Session header.
API СЕРВЕР	Node.js 20 Express PORT 3000	Локальная Windows-машина в офисе. Все data-эндпоинты защищены middleware requireAuth. Входящие запросы проходят через Cloudflare Tunnel (TLS).

УРОВЕНЬ	ТЕХНОЛОГИЯ	ОПИСАНИЕ
ТУННЕЛЬ	Cloudflare Tunnel api.sverdlik-apps.site	Encrypted tunnel: локальный порт 3000 → публичный домен. TLS termination на стороне Cloudflare. WAF rule активен: блок всех запросов вне Израиля.
DATA SOURCE	Power BI Fabric Azure AD DAX API	Данные клиентов и маршрутов загружаются через DAX-запросы с валидацией параметров. Azure AD Service Principal с минимальными правами (read-only).
СТАТИКА	GitHub Pages docs/	Публичные файлы: formula-road.html, иконки, манифест, formula-road-data.json (только updatedAt + список менеджеров). Данные клиентов и коды агентов в статике не публикуются.
CI/CD	GitHub Actions GitHub Secrets	Ежедневная сборка formula-road-data.json и планограмм. Все секреты в GitHub Secrets (не в коде). Workflow запускает только публикацию безопасных данных.

2. Активные меры защиты

2.1 Аутентификация и авторизация



Сессионные токены (8 часов) — POST /auth выдаёт UUID-токен. Все защищённые эндпоинты проверяют токен через requireAuth middleware. Без токена — HTTP 401.



Серверная валидация входа — пароль менеджера хранится только в .env на сервере, не в клиентском коде. Агенты валидируются по базе данных Power BI через /auth.



Разграничение прав — /save-karua (редактирование планограммы) доступен только менеджерам (isManager check в сессии). Агенты не могут изменять планограмму.



Автоматический выход — при получении HTTP 401 приложение автоматически очищает localStorage и требует повторного входа. Токен не хранится после истечения 8 часов.

2.2 Сетевая защита

-  **Cloudflare WAF — Geo-block** — активное правило "Block non-Israel": все запросы с IP вне Израиля блокируются на уровне Cloudflare до попадания на сервер.
-  **HTTPS обязателен** — Cloudflare Tunnel обеспечивает TLS для всего трафика. Незашифрованный HTTP не принимается.
-  **CORS ограничен** — сервер принимает запросы только от sverdlikdan-code.github.io и localhost. Посторонние сайты не могут обращаться к API.

2.3 Защита от злоупотреблений

-  **Rate limiting — аутентификация** — максимум 10 попыток входа в минуту с одного IP. При превышении — HTTP 429 на 60 секунд.
-  **Rate limiting — данные** — максимум 60 запросов в минуту с одного IP на все data-эндпоинты (/customers, /managers, /geocode и др.). Блокирует автоматический скрапинг.
-  **Лимит размера запросов** — максимум 512KB на тело POST-запроса. Защита от DoS через большие payload.
-  **Валидация входных данных** — код агента принимается только в формате цифр (\d+), имя менеджера — по whitelist символов. DAX-запросы не получают произвольный пользовательский ввод.

2.4 Защита приложения

-  **HTTP Security Headers** — X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy: no-referrer, X-XSS-Protection: 1; mode=block, Permissions-Policy.
-  **XSS защита в admin-интерфейсе** — все данные в /admin/logs HTML-экранируются через функцию esc() перед выводом.
-  **Минимальное раскрытие данных** — formula-road-data.json не содержит данных клиентов, GPS-координат, объёмов продаж и кодов агентов. Только список менеджеров и дата обновления.

2.5 Логирование и аудит

-  **Лог доступа** — каждый вход/выход записывается: timestamp (Israel TZ), имя агента, код, IP-адрес, тип устройства (mobile/desktop). Хранится в server/access-log.json (до 2000 записей).



Аудит-лог административных действий — каждое сохранение GPS-корректировки и изменение планаграммы логируется: кто, когда, какой объект.



Admin-панель просмотра логов — GET /admin/logs?key=KEY возвращает HTML-таблицу с последними 300 записями. Защищена отдельным ключом из .env.

3. Остаточные риски



Все риски безопасности данных устранены. Система полностью защищена: аутентификация, шифрование данных на диске, git-история очищена, API заблокирован без токена.

4. Мониторинг доступа

ЧТО ОТСЛЕЖИВАЕТСЯ	ГДЕ СМОТРЕТЬ	ФОРМАТ
Входы и выходы агентов и менеджеров	<code>GET /admin/logs?key=KEY</code>	HTML-таблица: время (Израиль), имя, IP, устройство
GPS-корректировки	<code>server/access-log.json</code>	event: gps-correction, custId, agentCode, IP
Изменения планограммы	<code>server/access-log.json</code>	event: planogram-save, количество позиций, IP
Отзыв сессии агента	<code>POST /admin/revoke?key=KEY&agentCode=CODE</code>	Немедленно инвалидирует все токены агента. Агент вынужден войти заново.
Заблокированные запросы (не из IL)	Cloudflare Dashboard → Security → Analytics	Карта по странам, Events last 24h в WAF rules

Ссылка для просмотра логов входа:

```
https://api.sverdlik-apps.site/admin/logs?key=[ADMIN_LOG_KEY из .env]
```

5. Модель угроз и уровень защищённости

СЦЕНАРИЙ УГРОЗЫ	ЗАЩИТА	УРОВЕНЬ
Внешний атакующий (не из Израиля) пытается получить данные клиентов	Cloudflare WAF блокирует запрос до попадания на сервер	Закрито
Перебор кодов агентов (brute force)	Rate limit 10 попыток/мин/IP + Israel-only	Закрито
Прямой вызов API без авторизации	requireAuth middleware — все data-эндпоинты требуют X-Session token	Закрито
Конкурент скачивает клиентскую базу скриптом	Токен + rate limit 60 req/min + Israel-only. Без токена — 401.	Закрито
Перезапись planoграммы чужим запросом	requireAuth + isManager проверка — только авторизованный менеджер	Закрито
Внедрение вредоносных GPS-координат	requireAuth + валидация координат (только Израиль) + аудит-лог	Закрито
Инъекция в DAX-запросы через параметры	Whitelist-валидация: agent=только цифры, manager=ограниченный charset	Закрито
XSS через данные в admin-панели	HTML-экранирование всех выводимых значений через esc()	Закрито
Публичный доступ к данным клиентов через GitHub Pages	formula-road-data.json не содержит клиентских данных и кодов агентов	Закрито